

capitolo 5 – La sicurezza delle comunicazioni in Rete

1. L'importanza della sicurezza informatica
2. Le tecniche crittografiche
3. La sicurezza nella suite TCP/IP e il firewall
4. La blockchain

5.1 L'importanza della sicurezza informatica

Indice

La **protezione della riservatezza** è diventata particolarmente importante nell'odierna **società dell'informazione**.

La **Costituzione della Repubblica italiana** sancisce all'**articolo 15** che «**la libertà e la segretezza della corrispondenza e di ogni altra forma di comunicazione sono inviolabili**».

Questo principio è messo in seria discussione nella società attuale, caratterizzata dalla **memorizzazione su larga scala di dati personali** e dal loro **trasferimento attraverso le reti di computer**.

5.1 L'importanza della sicurezza informatica

Indice

La **protezione della riservatezza** è diventata particolarmente importante nell'odierna **società dell'informazione**.

Per avere un'idea delle **dimensioni del traffico di dati sulla Rete** si può consultare il sito **internetlivestats.com**, che fornisce statistiche in tempo reale.

Alla fine del 2018 **Internet** ospitava circa **2 miliardi di siti web**.

I 4 miliardi di utenti di Internet **in ogni secondo** dell'anno in media:

- spedivano più di 2 700 000 e-mail;
- guardavano circa 75 000 video su YouTube;
- facevano circa 70 000 ricerche con Google;
- postavano più di 8000 tweet su Twitter;
- pubblicavano quasi 1000 foto su Instagram.

5.1 L'importanza della sicurezza informatica

Indice

Nelle reti **informatiche** sono possibili attacchi alla **riservatezza**, all'**integrità** e alla **disponibilità** dei **dati**.

La Rete deve garantire che:

- nessuno possa leggere il contenuto delle comunicazioni: **riservatezza**.
- soltanto gli utenti autorizzati possano modificare i dati sensibili: **integrità**.
- gli utenti legittimi possano accedere ai propri dati in ogni momento: **disponibilità**.

5.1 L'importanza della sicurezza informatica

Indice

La potenziale **vulnerabilità della Rete** ha portato negli ultimi decenni allo sviluppo di nuovi **strumenti di difesa**.

Per proteggere i dati nel corso delle comunicazioni tra host della Rete si usano **tecniche crittografiche**, codificando le informazioni con un codice condiviso tra mittente e destinatario.

Per bloccare eventuali **intrusioni** nei dispositivi di una rete locale si usa il **firewall** («muro di fuoco»), un dispositivo che fa da filtro tra la **LAN** e **Internet**.

5.2 Le tecniche crittografiche

Indice

La **crittografia** serve a mascherare un messaggio, così che risulti **comprensibile al solo destinatario**.

Si dice che il messaggio viene **criptato**, **codificato** o **cifrato**.

Quando poi con l'operazione inversa **si risale al messaggio originario**, si dice che il messaggio è stato **decriptato**, **decodificato** o **decifrato**.

Durante la Seconda guerra mondiale la Germania nazista **codificava tutti i messaggi militari** usando la complessa macchina elettromeccanica chiamata **Enigma**.

Decifrare questo sistema crittografico richiese anni di duro lavoro al gruppo guidato in Inghilterra da **Alan Turing**, che allo scopo costruì la macchina calcolatrice **bombe**.

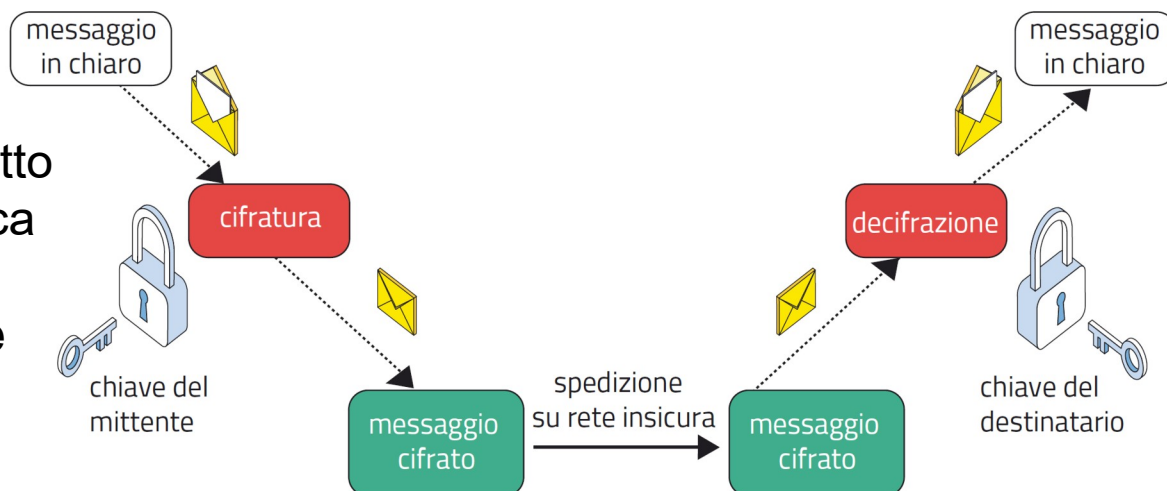


5.2 Le tecniche crittografiche

Indice

Con la tecnica della **crittografia** si rende **incomprensibile un messaggio**.

Al messaggio originale, detto **in chiaro**, il mittente applica un **algoritmo di cifratura** combinato con una **chiave segreta**: ottiene così il **messaggio cifrato**.



Il **messaggio cifrato** può essere trasmesso su qualsiasi canale, anche non sicuro: chi riuscisse a intercettarlo **non saprebbe decifrarlo**.

Per recuperare il messaggio in chiaro, il destinatario applica un **algoritmo di decifrazione** usando una **chiave segreta**, che può essere la stessa chiave usata dal mittente (**chiave simmetrica**) oppure una chiave diversa (**chiave asimmetrica**).

5.2 Le tecniche crittografiche

Indice

Nella **crittografia a chiave simmetrica** sia il mittente sia il destinatario usano la **stessa chiave segreta**.

Se K indica la chiave, l'algoritmo di cifratura C_K riceve in ingresso il **messaggio in chiaro** m e restituisce il **messaggio cifrato** c ottenuto come $c = C_K(m)$.

Il destinatario usa l'**algoritmo inverso** D_K , cioè decifra con la stessa chiave il messaggio cifrato, in modo da riottenere il messaggio in chiaro: $m = D_K(c)$.

5.2 Le tecniche crittografiche

Indice

Con il **metodo a sostituzione** la cifratura avviene **sostituendo ogni carattere del testo in chiaro con un carattere diverso**.

L'alfabeto di riferimento è quello inglese, composto da **26 lettere**, a ciascuna delle quali si assegna un numero in sequenza:

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25

Se ogni dato carattere è sostituito sempre dallo stesso simbolo, per esempio se la A è sempre sostituita dalla F, si parla di **codice monoalfabetico**.

Se con la somma si arriva in fondo all'alfabeto, si ritorna all'inizio.

In altre parole, l'addizione tra il numero di sequenza della lettera e la chiave va fatta in *modulo 26*: se la somma è maggiore di 25, al risultato si sottrae 26.

Esempio: se la **chiave è 12** e la lettera da codificare è **B**, che ha come numero di sequenza 01, allora la lettera cifrata sarà: $(01 + 12) \bmod 26 = 13 \rightarrow$ **lettera N**.

La **V** sarà invece sostituita da **H**, perché: $(21 + 12) \bmod 26 = 07 \rightarrow$ **lettera H**.

5.2 Le tecniche crittografiche

Un **metodo a sostituzione** più sofisticato è quello **polialfabetico**, in cui non è detto che una data lettera sia sostituita sempre dallo stesso carattere.

Con il metodo detto **autokey** la chiave è costituita da diverse sottochiavi, tante quante sono le lettere del messaggio da codificare: la prima sottochiave codifica la prima lettera, la seconda sottochiave la seconda lettera, e così via.

Esempio: codificare **ALLOCCO** usando 20 come prima sottochiave.

lettera in chiaro	A	L	L	O	C	C	O	
numero di sequenza	00	11	11	14	02	02	14	+
sottochiave	20	00	11	11	14	02	02	=
somma mod 26	20	11	22	25	16	04	16	
lettera cifrata	U	L	W	Z	Q	E	Q	

La parola **ALLOCCO** verrà cifrata come **ULWZQE.Q**.

5.2 Le tecniche crittografiche

Con i **metodi a trasposizione** le lettere vengono **spostate** nel testo, rimescolandole; **il testo cifrato è un *anagramma*** del testo in chiaro.

Esempio: il mittente vuole spedire il testo in chiaro **UNDICISETTEMBRE**.

1. Lo riporta in una tabella di 5 righe e 3 colonne, scrivendolo per righe;
2. poi scambia tra loro la prima e la terza colonna.

U	N	D
I	C	I
S	E	T
T	E	M
B	R	E

D	N	U
I	C	I
T	E	S
M	E	T
E	R	B

Il **testo cifrato** sarà quello della nuova tabella letto **per colonne**:
DITMENCEERUISTB.

5.2 Le tecniche crittografiche

Indice

Con l'**informatica** non si codificano più lettere dell'alfabeto ma **blocchi di bit**, con **sostituzioni**, **trasposizioni**, **scambi** o **ricombinazioni**.

Si usa anche l'**operatore logico OR esclusivo (XOR)**, che produce un bit **1** in uscita soltanto quando i due bit in ingresso sono **diversi** tra loro.

Esempio:

blocco in chiaro	1	1	0	0	1	0	0	0
chiave	1	0	0	0	1	1	1	0
blocco codificato XOR	0	1	0	0	0	1	1	0

5.2 Le tecniche crittografiche

Indice

Un esempio di **codifica moderna** è il **DES (Data Encryption Standard)**.

La codifica si può sperimentare con il simulatore all'indirizzo **web des.online-domain-tools.com**.

Ciascuna delle **16 fasi** del metodo usa una **chiave di 48 bit** e due sistemi di cifratura: il ***mixing*** (mescolamento) e lo **scambio** delle metà destra e sinistra del blocco.

The screenshot shows the 'DES - Symmetric Ciphers Online' web application. The interface includes the following elements:

- Input type:** A dropdown menu set to 'Text'.
- Input text: (hex):** A text box containing '7777777777777777a'.
- Autodetect:** A toggle switch set to 'OFF'.
- Function:** A dropdown menu set to 'DES'.
- Mode:** A dropdown menu set to 'ECB (electronic codebook)'.
- Key: (plain):** A text box containing 'test-key'.
- Radio buttons:** 'Plaintext' is selected, and 'Hex' is unselected.
- Buttons:** Two green buttons labeled '> Encrypt!' and '> Decrypt!'. A mouse cursor is hovering over the 'Encrypt!' button.
- Output:** At the bottom, it shows 'Encrypted text: 1d 60 a8 91 fb e7 91 27' followed by a series of small icons.

5.2 Le tecniche crittografiche

Un esempio di **codifica moderna** è il **DES** (*Data Encryption Standard*).

Questo è il risultato della **codifica DES**, con la stessa chiave, di due sequenze che differiscono soltanto per l'ultimo dei 64 bit:

sequenza hex in chiaro	chiave	sequenza hex cifrata
77 77 77 77 77 77 77 7a	test-key	1d 60 a8 91 fb e7 91 27
77 77 77 77 77 77 77 7b	test-key	5a 79 cc 77 16 bb 7f c8

Due **sequenze di input quasi identiche** vengono codificate dal DES con due **sequenze cifrate completamente diverse** tra loro!

Oggi però si preferisce usare l'**AES** (*Advanced Encryption Standard*), che migliora l'algoritmo del DES nei suoi punti più deboli.

5.2 Le tecniche crittografiche

Indice

In molti casi è preferibile usare la **crittografia asimmetrica**.

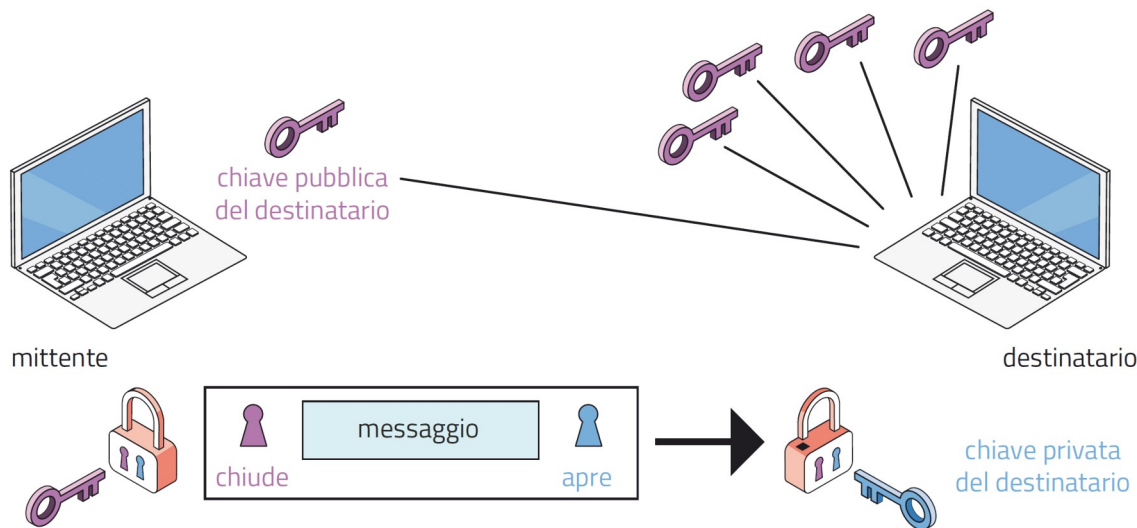
Per poter usare la crittografia a chiave **simmetrica**, due interlocutori prima di iniziare la comunicazione criptata devono scambiarsi messaggi per concordare la chiave segreta; **in questa fase però le comunicazioni sono in chiaro**, perciò **la chiave può essere facilmente intercettata**.

Per risolvere questo problema, nel 1976 Whitfield Diffie e Martin Hellman idearono all'Università di Stanford **un sistema di crittografia che prevede l'uso di una coppia di chiavi, una segreta (o privata) e una pubblica**.

5.2 Le tecniche crittografiche

Indice

Per scambiarsi la chiave segreta con riservatezza si usa la **crittografia asimmetrica**.



La chiave pubblica è usata per **codificare i messaggi**, mentre la **chiave privata**, mantenuta segreta, serve a chi riceve i messaggi **per decodificarli**.

Chi vuole ricevere messaggi criptati **fornisce la propria chiave pubblica**.

Il mittente codifica il messaggio **con quella chiave** e lo invia.

Il destinatario, ricevuto il messaggio, **lo decodifica con la sua chiave privata**, che **nessun altro conosce**.

5.2 Le tecniche crittografiche

Indice

Il **sistema più noto di crittografia a chiave pubblica** è l'**RSA**, dalle iniziali degli inventori **Ronald Rivest, Adi Shamir e Leonard Adleman**.

Se m è il messaggio in chiaro e c il messaggio cifrato, l'**algoritmo RSA funziona in questo modo**:

1. seleziona due numeri primi p e q molto grandi e ne calcola il prodotto n ;
2. seleziona due numeri e e d tali che $c = m^e \bmod n$ e che $m = c^d \bmod n$;
3. rende pubblica la chiave costituita dalla coppia (e, n) ;
4. fornisce al destinatario la chiave privata costituita dalla coppia (d, n) , che va custodita con segretezza.

Chi vuole spedire un messaggio m applica la formula $\mathbf{c = m^e \bmod n}$, usando i valori di $\mathbf{e}$ e $\mathbf{n}$ contenuti nella chiave pubblica, poi invia il messaggio cifrato $\mathbf{c}$.

Il destinatario – che è l'unico a conoscere il valore di $\mathbf{d}$ – decifrerà il messaggio applicando la formula inversa $\mathbf{m = c^d \bmod n}$.

L'algoritmo **RSA** è sicuro perché **usa due numeri primi p e q grandissimi**, lunghi più di 300 cifre, e fattorizzare il prodotto di p e q è estremamente difficile.

5.2 Le tecniche crittografiche

Indice

La **firma digitale** è un'autenticazione di un messaggio resa possibile dalla **crittografia a chiave pubblica**.

Per firmare digitalmente bisogna dotarsi di una **smart card** che ha due funzioni: **genera la coppia di chiavi, pubblica e privata, e usa la chiave privata per fare la codifica**.

Per velocizzare le operazioni, però, non viene cifrato l'intero documento, bensì una sua selezione o **digest**, che è come un'«**impronta digitale**» del documento e lo identifica univocamente.

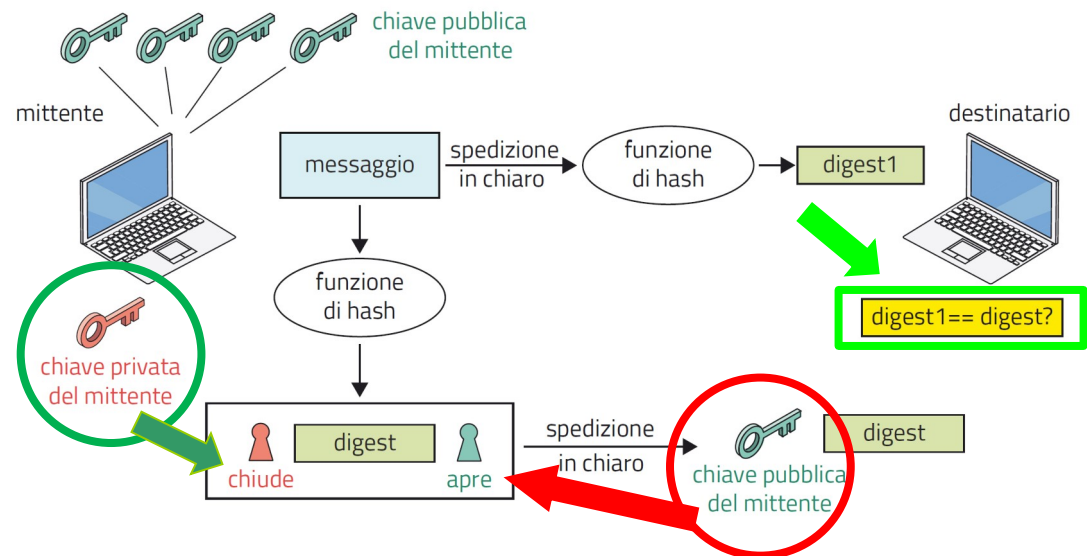
Il **digest** è una **sequenza di pochi byte** che si ottiene applicando al documento da inviare un particolare tipo di funzione, detto **funzione di hash**.

5.2 Le tecniche crittografiche

Indice

La **firma digitale** è un'autenticazione di un messaggio resa possibile dalla crittografia a chiave pubblica.

Il **digest** è cifrato con la **chiave privata** del mittente, mentre il documento viene **spedito in chiaro**.



Il **destinatario**, per verificare la firma, **usa la chiave pubblica per decodificare il digest**, applica la funzione di hash al documento ricevuto e **confronta il digest** così ottenuto con il **digest decodificato**.

Se i due **digest** coincidono, il documento è integro e la **firma è autentica**:

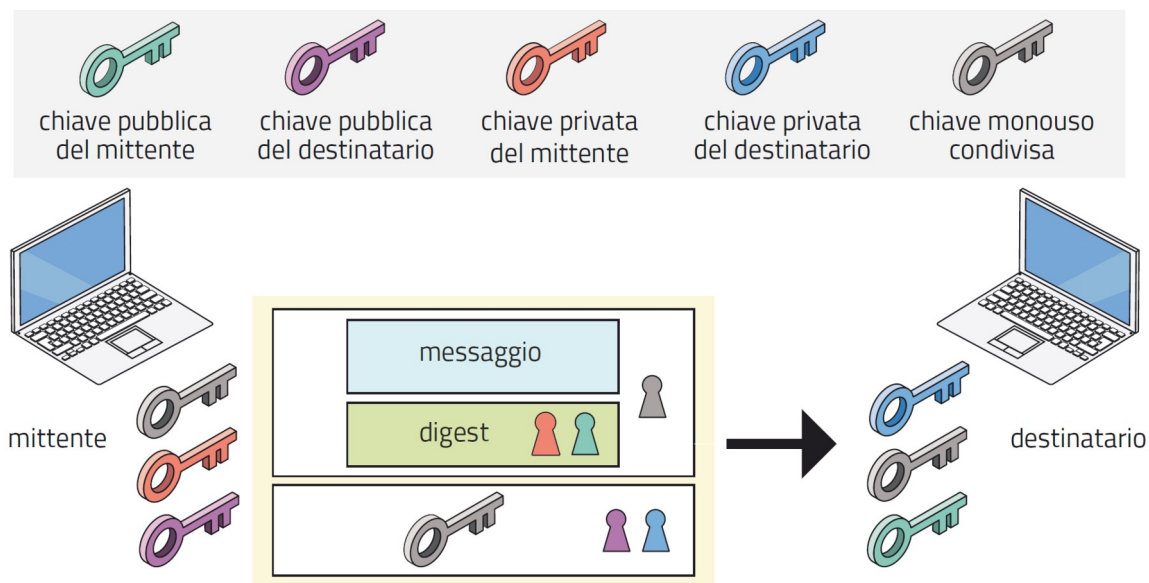
5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Per la **segretezza e l'integrità dei messaggi di posta elettronica** si usa il protocollo **PGP (Pretty Good Privacy)**, che **autentica anche il mittente**.

La comunicazione via **e-mail non è in tempo reale**: manca la fase di **handshaking** per concordare **algoritmi e hash di cifratura**.

Queste informazioni **sono inserite nel messaggio**. Il destinatario, per prima cosa, le estrarrà per sapere quali algoritmi usare.



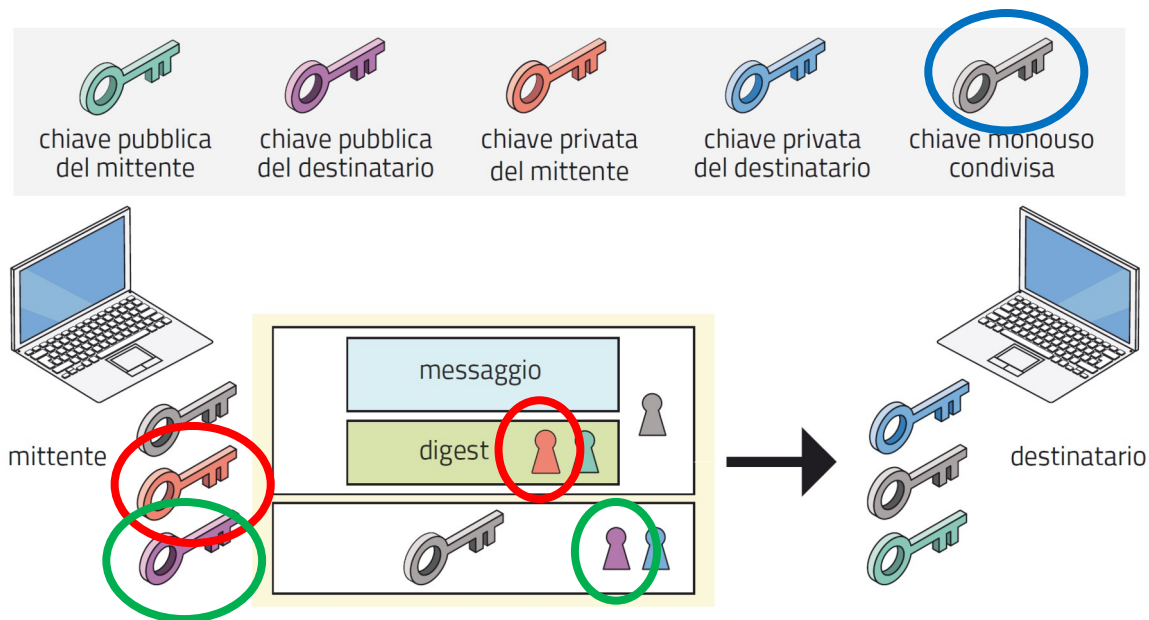
5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Per la **segretezza e l'integrità dei messaggi di posta elettronica** si usa il protocollo **PGP (Pretty Good Privacy)**, che **autentica anche il mittente**.

Il **mittente** agisce così:

1. codifica il digest del messaggio con la propria chiave privata;
2. crea una chiave simmetrica *monouso*, solo per questo messaggio, e la usa per codificare messaggio e digest
3. invia – separatamente – anche la chiave monouso, codificandola con la chiave pubblica del destinatario.



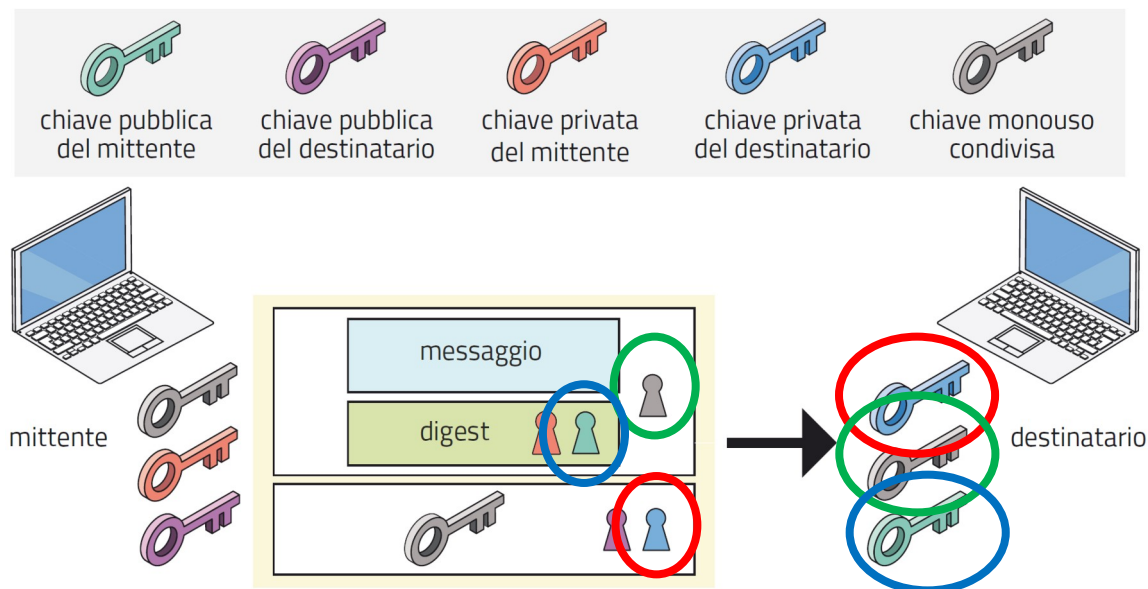
5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Per la **segretezza e l'integrità dei messaggi di posta elettronica** si usa il protocollo **PGP (Pretty Good Privacy)**, che **autentica anche il mittente**.

Il **destinatario**, quando riceve tutte le informazioni:

1. con la chiave privata decifra la chiave monouso;
2. con la chiave monouso decifra l'insieme di messaggio e digest;
3. con la chiave pubblica del mittente decifra il digest;
4. crea un digest del messaggio e controlla che coincida con il digest appena decifrato; se i due digest sono identici, significa che il messaggio è autentico.



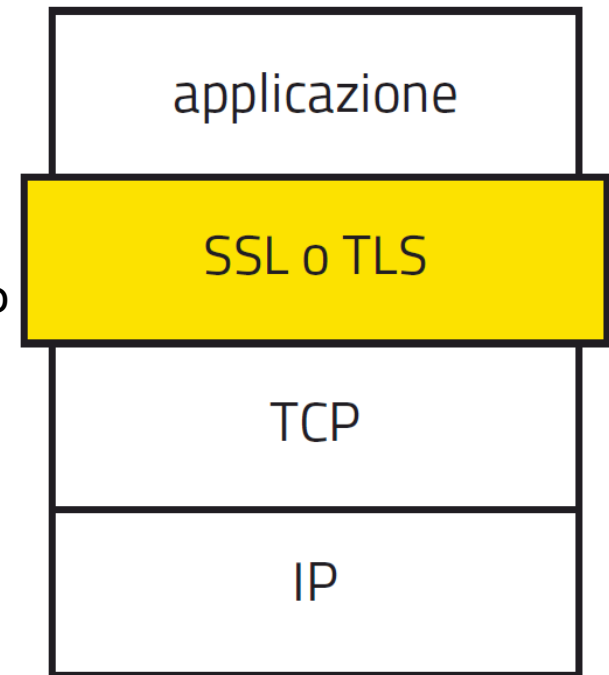
5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Per la sicurezza delle comunicazioni, tra il **TCP** e le **applicazioni del livello superiore** si aggiunge il protocollo **SSL** o il più recente **TLS**.

L'**SSL** (*Secure Socket Layer*) o il **TLS** (*Transport Layer Security*) riceve i dati dall'applicazione, li comprime e codifica, poi li passa al protocollo TCP.

Si tratta di un **ulteriore livello** che si interpone tra lo **strato applicazione** e lo **strato trasporto** della suite TCP/IP.



5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Per la sicurezza delle comunicazioni, tra il **TCP** e le **applicazioni del livello superiore** si aggiunge il protocollo **SSL** o il più recente **TLS**.

I **datagram** del **protocollo HTTP**, per esempio, non passano direttamente al **segmento TCP** ma sono affidati all'**SSL**, che confeziona messaggi di tipo **HTTPS**, dove la **S** sta per «sicuro».

I siti che usano il protocollo SSL (o il **TLS**) hanno un **URL** che inizia con **https://** anziché **http://**.

Il loro indirizzo nella **barra del browser** è accompagnato dall'icona di un **lucchetto**.



Il **TLS** garantisce la protezione dell'URL richiesto, dei parametri inclusi nella richiesta, delle intestazioni e dei **cookie**.

L'HTTPS non può però garantire la sicurezza sulle porte del livello TCP.

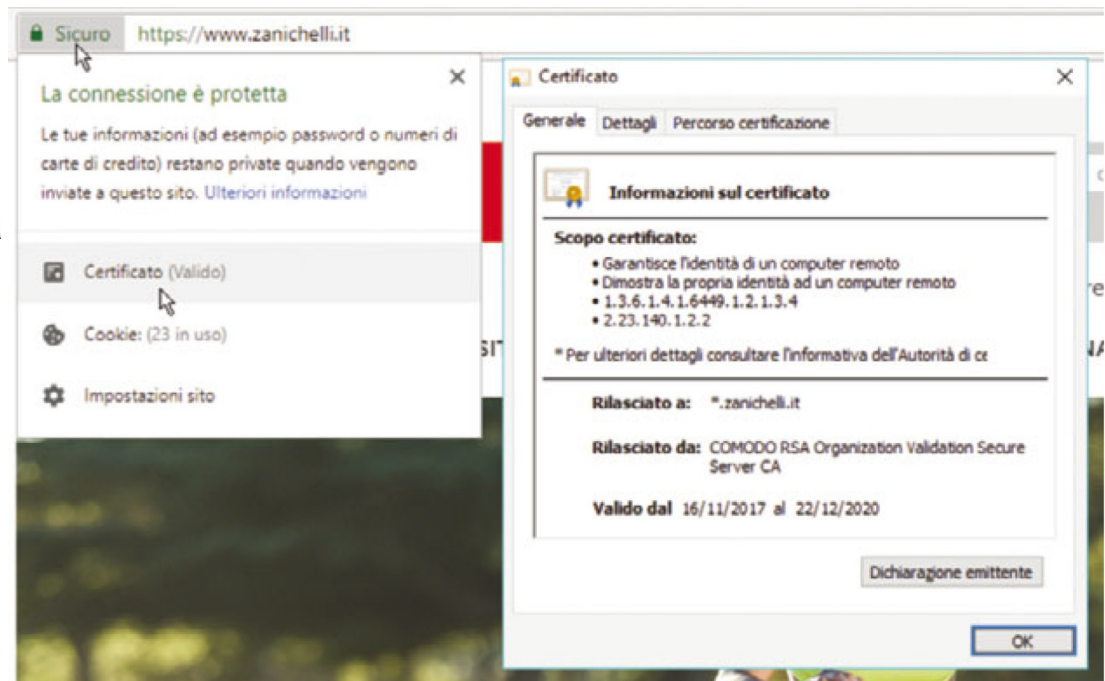
5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

I **siti sicuri** sono dotati di un **certificato** che ne **attesta la proprietà**.

Questi siti sono dotati di un **certificato di sicurezza** rilasciato da un'**autorità di certificazione**, che ne attesta la proprietà.

I dettagli del certificato si possono visualizzare facendo clic sul lucchetto a sinistra dell'URL e poi su **Certificato**.



5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

I **siti sicuri** sono dotati di un **certificato** che ne **attesta la proprietà**.

I **protocolli SSL e TLS** sono usati dai siti che richiedono lo scambio di dati sensibili tra il client e il server, come le banche o le pubbliche amministrazioni, ma si stanno diffondendo sempre più in siti di ogni tipo.

Dal 2017 il motore di ricerca Google ha deciso di penalizzare, marchiandoli come non sicuri, i siti che non fanno uso dell'SSL.

Anche i browser a volte li segnalano visualizzando messaggi di avviso in ottemperanza al **GDPR** (*General Data Protection Regulation*), che è il **Regolamento generale sulla protezione dei dati dell'Unione Europea**.

5.3 La sicurezza nella suite TCP/IP e il firewall

Indice

Il firewall agisce soltanto sui livelli di trasporto e IP.

Il **firewall** è un dispositivo costituito da **hardware e software**, per esempio un router o un computer, che **si frappone tra la LAN e la Rete** per analizzare il traffico in ingresso e in uscita e stabilire quali messaggi vadano bloccati.

Il firewall analizza gli **indirizzi IP e i numeri di porta della sorgente e del destinatario**. Può quindi bloccare i pacchetti in entrata provenienti da una particolare rete, oppure quelli destinati a una determinata porta o a uno specifico host della LAN.

Può agire anche sui pacchetti in uscita: se per esempio blocca le comunicazioni in uscita destinate alla porta 80, che identifica il protocollo HTTP, i dispositivi collegati alla LAN non possono accedere a Internet.

Il firewall può intervenire soltanto sui livelli di trasporto e IP.
Per i livelli superiori deve intervenire un proxy server.

5.4 La blockchain

Indice

La **blockchain** è una tecnica rivoluzionaria usata per **autenticare e registrare le transazioni online senza ricorrere a intermediari**.

La **blockchain** è un «libro mastro» (in inglese *ledger*) virtuale, cioè un **registro digitale di informazioni** gestito da una **serie di nodi della Rete**.

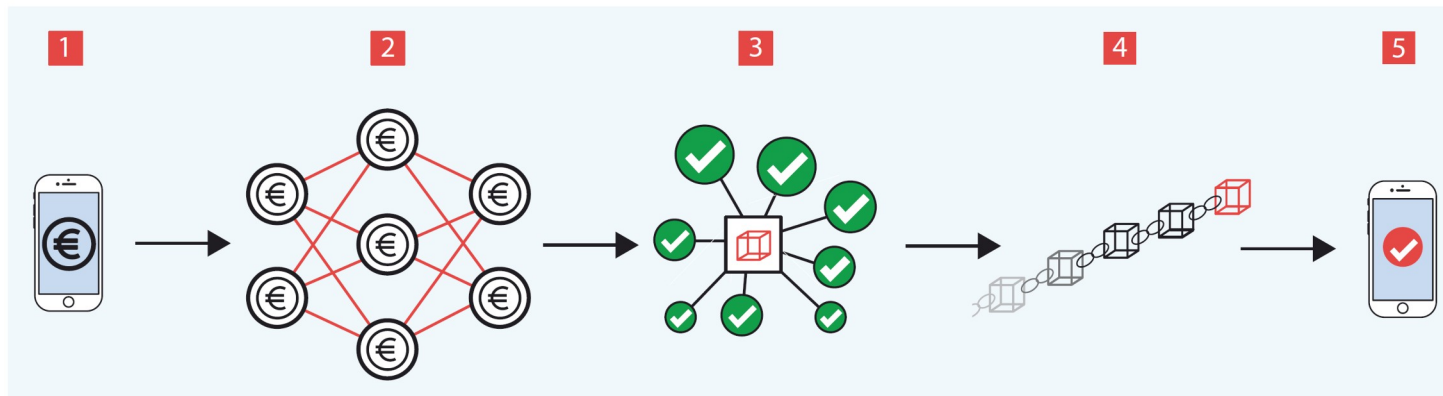
Ogni nodo possiede una copia privata del registro; quando una transazione è gestita attraverso la blockchain, i dati relativi alla transazione **vengono memorizzati su tutti i nodi** e vanno a formare un **nuovo blocco della catena**.

Diventa così impossibile modificare o cancellare l'operazione memorizzata, perché ve ne è traccia su tutti i registri presenti nella Rete e **non è possibile modificare contemporaneamente tutti quei registri**.

5.4 La blockchain

Indice

I nodi della **blockchain** possono essere attivati da chiunque, **senza certificazione da parte di intermediari.**



1. Un utente chiede di effettuare una transazione.
2. La richiesta va a una rete di tipo *peer-to-peer*, che la trasmette a tutti nodi.
3. Ogni nodo convalida la transazione con un opportuno algoritmo crittografico.
4. La transazione approvata viene aggiunta come nuovo blocco al libro mastro.
5. L'utente riceve conferma che la transazione è completata e registrata in modo permanente.

5.4 La blockchain

Indice

La **blockchain** è divenuta celebre come **tecnologia alla base del *bitcoin***, la prima «**valuta virtuale**» introdotta come software open source nel 2009.

Il **denaro virtuale** è anche detto **crittomoneta**, per via delle **tecniche crittografiche usate per generarlo**, memorizzarlo e scambiarlo in transazioni mediante la blockchain.



Con il denaro virtuale **non esiste intermediazione**: grazie al meccanismo della blockchain, che fa da certificatore automatico, **venditore e acquirente stipulano il loro accordo senza dover far riferimento ad alcuna autorità centrale**.

Ogni blocco della blockchain contiene una copia del blocco precedente: questo fatto rende il registro digitale permanente e non modificabile.

Il libro mastro delle transazioni è pubblico e accessibile da chiunque via Internet, ma garantisce la privacy e la sicurezza, perché **i dati relativi alle singole transazioni sono crittografati.**

I titolari di ogni transazione possono decidere se pubblicarne o meno il contenuto.

Molte transazioni sono fatte in modo anonimo; questa caratteristica del denaro virtuale è spesso criticata, perché la si può sfruttare per coprire operazioni illegali.